

SSH — Secure Shell

Servicio

SSH (Secure Shell)

Puerto por defecto

22/TCP

Descripción

SSH es un protocolo criptográfico de red diseñado para operar servicios de red de forma segura sobre una red no protegida. Proporciona acceso remoto a la línea de comandos, transferencia de archivos (SCP/SFTP) y tunelización de puertos con cifrado end-to-end. Es el reemplazo seguro de Telnet y rlogin.

Riesgos de seguridad

- **Fuerza bruta sobre contraseñas:** Los atacantes lanzan ataques automatizados de diccionario contra el servicio SSH expuesto en Internet.
- **Robo de credenciales / claves privadas:** Claves SSH comprometidas permiten acceso persistente sin contraseña.
- **Root login habilitado:** Permitir el acceso directo como root amplifica el impacto de cualquier compromiso.
- **Versiones obsoletas de OpenSSH:** Versiones antiguas pueden contener vulnerabilidades conocidas (CVE publicados).
- **Configuración débil de cifrado:** Algoritmos de cifrado o MAC obsoletos (ej. MD5, arcfour) son vulnerables a ataques criptográficos.

Escenarios de ataque

1. **Ataque de fuerza bruta:** Herramientas como Hydra o Medusa prueban combinaciones de usuario/contraseña contra el puerto 22 hasta obtener acceso.
2. **Credential stuffing:** Uso de credenciales filtradas de otras brechas para autenticarse en servidores SSH expuestos.
3. **Compromiso de clave privada:** Un atacante que roba el archivo `~/.ssh/id_rsa` del cliente puede hacerse pasar por el usuario legítimo sin contraseña.
4. **Man-in-the-Middle (MITM) en primer conexión:** Si el usuario acepta una huella digital de host desconocida, un atacante puede interceptar la sesión.

Mitigaciones recomendadas

- Deshabilitar autenticación por contraseña; usar **autenticación por par de claves**

(PasswordAuthentication no).

- **Deshabilitar login de root** (PermitRootLogin no).
- Cambiar el puerto por defecto (22) a uno no estándar para reducir ruido de escaneos automatizados.
- Implementar **fail2ban** o similar para bloquear IPs con múltiples intentos fallidos.
- Restringir acceso por IP con AllowUsers, AllowGroups o reglas de firewall (UFW/iptables).
- Mantener OpenSSH actualizado y deshabilitar algoritmos débiles en sshd_config.
- Habilitar **autenticación multifactor (MFA)** con Google Authenticator o similar.
- Usar **Port Knocking** o VPN para ocultar el servicio SSH del escaneo público.

Nivel de exposición

Medio (Alto si está expuesto a Internet sin restricciones de acceso o con autenticación por contraseña habilitada)

Referencias

- OpenSSH Project. *OpenSSH Manual Pages*. <https://www.openssh.com/manual.html>
- NIST. *Cybersecurity Framework*. <https://www.nist.gov/cyberframework>
- CIS. *CIS Benchmarks — Linux*. <https://www.cisecurity.org/cis-benchmarks>
- NIST SP 800-53 Rev. 5 — Control AC-17 (Remote Access). <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>